
CYBERSECURITY RISK REGISTER AND ASSESSMENT REPORT

Alderbridge Financial Services Ltd

A NIST Cybersecurity Framework Aligned Risk Assessment

Prepared by: Reward Oladejo-Olagboye

Report date: 29 July 2026

Framework: NIST Cybersecurity Framework (CSF)

Classification: Confidential, Board and Executive Leadership Distribution Only

Note: Alderbridge Financial Services Ltd is a fictional organisation created for the purpose of demonstrating a structured cybersecurity risk assessment methodology.

Document Control

Field	Detail
Document Title	Cybersecurity Risk Register and Assessment Report
Organisation	Alderbridge Financial Services Ltd (fictional)
Version	1.0
Author	Reward Oladejo-Olagboye
Date	29 July 2026
Framework	NIST Cybersecurity Framework (CSF)
Classification	Confidential
Distribution	Board Risk Committee, Executive Leadership Team

Table of Contents

1. Executive Summary 4

2. Scope and Objectives..... 4

3. Methodology 5

4. Risk Register 6

5. Risk Analysis: Top Priority Risks 7

6. Control Recommendations and Roadmap..... 8

7. Conclusion 9

Appendix A: Risk Scoring Reference 10

Appendix B: Assumptions and Limitations 10

Appendix C: Glossary of Terms..... 10

1. Executive Summary

This report presents a cybersecurity risk assessment conducted for Alderbridge Financial Services Ltd, a UK regulated financial services provider offering retail banking, personal lending and payment processing services. The assessment was carried out using the National Institute of Standards and Technology Cybersecurity Framework as the primary structuring model, covering the five core functions of Identify, Protect, Detect, Respond and Recover.

Eighteen risks were identified across the organisation's technology estate, spanning legacy infrastructure, identity and access management, third party dependencies, monitoring capability, incident response readiness and business continuity arrangements. Of these, three were rated High after accounting for existing controls, principally relating to the unsupported legacy core banking platform, untested incident response arrangements and untested backup restoration procedures. A further group of risks remain at Medium after controls, including limited monitoring coverage across cloud hosted payment platforms and the absence of a payment specific continuity plan.

The findings indicate that while Alderbridge maintains a reasonable baseline of technical controls, a number of foundational governance gaps, particularly around testing, documentation and third party oversight, materially increase the organisation's exposure to operational disruption and regulatory scrutiny. A phased remediation roadmap is proposed, prioritising the highest rated risks for action within the next 30 to 90 days, with the remaining risks addressed across a 6 to 12 month programme.

This document is intended to support the Board Risk Committee and Executive Leadership Team in understanding the organisation's current risk posture and in allocating resource toward the highest priority remediation activities.

2. Scope and Objectives

2.1 Purpose

The purpose of this assessment is to identify, evaluate and prioritise cybersecurity risks across Alderbridge Financial Services Ltd's technology environment, and to provide the Board Risk Committee with a clear, evidence based view of the organisation's current risk exposure.

2.2 Scope

This assessment covers the technology systems, infrastructure and third party relationships that support Alderbridge's core retail banking and payment processing operations, including:

- Core banking platform and supporting infrastructure
- Cloud hosted payment processing systems
- Identity and access management arrangements for staff and privileged users
- Third party vendor and supplier technology relationships
- Security monitoring and incident response capability
- Backup, recovery and business continuity arrangements

The following areas fall outside the scope of this assessment: physical security of branch premises, human resources policy matters unrelated to access control, and customer facing marketing channels not directly involved in payment processing.

2.3 Why NIST CSF

The NIST Cybersecurity Framework was selected as the structuring model for this assessment because it provides a widely recognised, function based view of cybersecurity risk that maps clearly onto both technical controls and governance activity. Organising risks under Identify, Protect, Detect, Respond and Recover allows the Board to see

not only where individual weaknesses exist, but where the organisation's overall capability is weakest across the full risk lifecycle.

3. Methodology

3.1 Risk Identification Approach

Risks were identified through a structured review of Alderbridge's technology estate, informed by common risk themes observed across the financial services sector, including legacy system exposure, third party dependency, identity and access weaknesses, and gaps in monitoring and response capability. Each identified risk was assessed against its likelihood of occurrence and the potential impact to the organisation should it materialise.

3.2 Likelihood and Impact Scoring

Each risk was scored on two five point scales, likelihood and impact, as set out below.

Likelihood Scale

- 1, Rare: unlikely to occur within the next 12 months
- 2, Unlikely: may occur once within the next 12 to 24 months
- 3, Possible: may reasonably occur within the next 12 months
- 4, Likely: expected to occur within the next 6 to 12 months
- 5, Almost Certain: expected to occur within the next 3 months, or already occurring

Impact Scale

- 1, Negligible: minimal disruption, no financial or regulatory consequence
- 2, Minor: localised disruption, low cost to remediate, no regulatory involvement expected
- 3, Moderate: noticeable service disruption, moderate financial cost, possible regulatory scrutiny
- 4, Major: significant service disruption, substantial financial loss, likely regulatory investigation or enforcement action
- 5, Severe: critical failure of core services, severe financial and reputational damage, regulatory action expected

3.3 Risk Rating Matrix

Inherent and residual risk ratings were calculated by multiplying the likelihood score by the impact score, producing a rating between 1 and 25. Ratings were then banded as follows:

- 1 to 6, Low
- 7 to 12, Medium
- 13 to 19, High
- 20 to 25, Critical

Inherent risk reflects the risk level before existing controls are taken into account. Residual risk reflects the risk level once existing controls have been applied, and is the rating used to prioritise remediation activity.

4. Risk Register

The full register of eighteen identified risks is set out below, organised by NIST Cybersecurity Framework function. Inherent and residual risk ratings are shaded according to the bands defined in Section 3.3.

ID	Risk Description	NIST CSF Function	Likelihood	Impact	Inherent Risk	Existing Controls	Residual Risk	Risk Owner
R01	Incomplete and outdated asset inventory across core banking and supporting infrastructure	Identify	3	3	9 (Medium)	Annual manual asset audit conducted by IT operations	6 (Low)	Head of IT Infrastructure
R02	Undocumented and unmanaged third party vendor technology relationships, including payment gateway providers	Identify	4	3	12 (Medium)	Procurement conducts basic due diligence at onboarding only	9 (Medium)	Head of Procurement and Vendor Risk
R03	Absence of a formal data classification standard for customer financial records	Identify	3	3	9 (Medium)	Data handled under general data protection policy, no formal classification levels	9 (Medium)	Data Protection Officer
R04	No formal risk assessment process applied to new digital product launches	Identify	3	3	9 (Medium)	Ad hoc technical review by engineering leads prior to launch	6 (Low)	Head of Product and Technology
R05	Core banking platform runs on an unsupported legacy operating system with no vendor security patching available	Protect	4	5	20 (Critical)	Network segmentation and compensating firewall rules around the legacy environment	16 (High)	Head of IT Infrastructure
R06	Multi factor authentication is not consistently enforced across all privileged and administrative accounts	Protect	4	4	16 (High)	MFA enforced for remote access only, not for on premises privileged sessions	9 (Medium)	IAM Lead
R07	Weak segregation of duties within payment approval workflows allows a single user to initiate and approve high value transactions	Protect	3	5	15 (High)	Manual monthly review of high value transaction logs	8 (Medium)	Head of Payments Operations
R08	Inadequate encryption of customer financial data at rest within the core customer database	Protect	3	5	15 (High)	Database access restricted to named administrators only	12 (Medium)	Head of IT Infrastructure
R09	Absence of a formal joiner mover leaver process resulting in delayed access revocation for departing staff	Protect	3	3	9 (Medium)	Quarterly manual access review conducted by IT	6 (Low)	Head of HR and IAM Lead
R10	Insufficient security awareness training coverage for staff handling financial transactions	Protect	3	3	9 (Medium)	Annual generic compliance training, not role specific	6 (Low)	Head of Learning and Development
R11	Limited security monitoring coverage across cloud hosted payment processing platforms	Detect	4	4	16 (High)	On premises SIEM in place, cloud platforms not yet integrated	12 (Medium)	SOC Manager
R12	No formal threat intelligence feed integrated into security monitoring operations	Detect	3	3	9 (Medium)	Ad hoc review of public vendor advisories	6 (Low)	SOC Manager
R13	Delayed review cadence for privileged account activity logs, typically reviewed monthly rather than near real time	Detect	3	3	9 (Medium)	Monthly manual log review by IT security team	6 (Low)	SOC Manager
R14	Incident response plan has not been tested through a simulation or tabletop exercise within the last 12 months	Respond	4	5	20 (Critical)	Documented incident response plan exists but has not been rehearsed	16 (High)	Head of Information Security
R15	No clearly defined communication plan for regulatory breach notification to the FCA and ICO	Respond	3	4	12 (Medium)	General escalation contacts documented, no formal notification playbook	8 (Medium)	Head of Compliance
R16	Backup restoration procedures for core banking systems have not been tested within the last 12 months	Recover	4	5	20 (Critical)	Nightly backups taken and stored offsite, restoration not verified	16 (High)	Head of IT Operations
R17	No documented business continuity plan specific to a payment processing outage	Recover	4	5	20 (Critical)	General organisational business continuity plan exists, not payment specific	12 (Medium)	Head of Operational Resilience
R18	Single cloud hosting provider dependency for payment processing infrastructure with no failover arrangement	Recover	3	5	15 (High)	Contractual SLA in place with hosting provider, no secondary provider	12 (Medium)	Head of IT Infrastructure

ID = Identify PR = Protect DE = Detect RS = Respond RC = Recover

5. Risk Analysis: Top Priority Risks

The six risks below carry the highest inherent risk ratings identified in this assessment and are examined in greater detail to support Board level decision making.

R05: Legacy Core Banking System Running an Unsupported Operating System

Business Context: The platform underpinning retail deposit accounts and payment initiation runs on an operating system that has reached end of vendor support, meaning no further security patches are issued for newly discovered vulnerabilities.

Why This Matters: This is the single largest concentration of risk in the assessment. A successful exploit against the core banking platform would affect every customer account and payment transaction processed through it, carrying severe financial, operational and regulatory consequences under the FCA's operational resilience requirements.

Current Exposure: Rated Critical before controls and High after compensating network segmentation, since segmentation reduces exposure but does not remove the underlying vulnerability.

Recommended Action: Commission a structured migration plan to a supported platform, and in the interim strengthen compensating controls including enhanced monitoring and strict network isolation of the legacy environment.

R06: Inconsistent Multi Factor Authentication on Privileged Accounts

Business Context: Multi factor authentication is enforced for staff connecting remotely, but privileged and administrative accounts accessed from within the corporate network are not currently required to use it.

Why This Matters: Privileged accounts hold the highest level of access across the estate. An attacker who gains a foothold inside the corporate network, whether through phishing or an insider threat, could move to sensitive systems without a second authentication factor in place.

Current Exposure: Rated High before controls and Medium after existing partial MFA coverage on remote access.

Recommended Action: Extend MFA enforcement to all privileged and administrative accounts regardless of connection origin, prioritising database administrators and infrastructure engineers first.

R11: Limited Security Monitoring Coverage on Cloud Hosted Payment Platforms

Business Context: The organisation's Security Information and Event Management (SIEM) capability was built around on premises infrastructure and has not yet been extended to the cloud hosted platforms that process card payments.

Why This Matters: Payment processing is one of the most attractive targets for financially motivated attackers. A gap in monitoring coverage here means malicious activity could go undetected for an extended period, directly affecting PCI DSS compliance obligations.

Current Exposure: Rated High before controls and Medium after existing on premises coverage.

Recommended Action: Integrate cloud payment platform logging into the existing SIEM, and define detection use cases specific to payment fraud and unauthorised access patterns.

R14: Untested Incident Response Plan

Business Context: A documented incident response plan exists, covering roles, escalation paths and containment steps, but it has not been exercised through a tabletop simulation or live drill in the last 12 months.

Why This Matters: A plan that has never been rehearsed frequently fails under real conditions, whether through unclear ownership, outdated contact details or unrealistic assumptions about system recovery time. This is consistently one of the most common findings in real world post incident reviews.

Current Exposure: Rated Critical before controls and High after accounting for the existence of a documented, though unrehearsed, plan.

Recommended Action: Schedule a tabletop exercise within the next 30 days simulating a realistic payment fraud or ransomware scenario, and update the plan based on lessons identified.

R16: Untested Backup Restoration Procedures

Business Context: Nightly backups of core banking data are taken and stored offsite, but the organisation has not verified that these backups can be successfully restored within an acceptable recovery time.

Why This Matters: A backup that cannot be restored provides no real protection against ransomware or catastrophic data loss. This gap directly undermines the organisation's ability to recover core services within its stated recovery time objectives.

Current Exposure: Rated Critical before controls and High after accounting for the existence of regular, though unverified, backups.

Recommended Action: Perform a full restoration test of core banking data within the next 30 days, and establish a recurring quarterly restoration testing schedule.

R17: No Payment Specific Business Continuity Plan

Business Context: A general organisational business continuity plan exists, but it does not contain specific procedures for responding to a sustained outage of payment processing infrastructure.

Why This Matters: Payment processing is the organisation's most customer visible and revenue critical function. A generic continuity plan is unlikely to provide the specific technical failover steps, communication templates and recovery time targets needed to manage a payment outage effectively.

Current Exposure: Rated Critical before controls and Medium after accounting for the general continuity plan already in place.

Recommended Action: Develop a payment processing specific continuity annex, including failover procedures, customer communication templates and defined recovery time and recovery point objectives.

6. Control Recommendations and Roadmap

6.1 Immediate (0 to 30 Days)

- Conduct and document a tabletop exercise to test the incident response plan (R14)
- Perform and verify a full backup restoration test for core banking systems (R16)
- Extend MFA enforcement to all on premises privileged and administrative accounts (R06)

6.2 Short Term (30 to 90 Days)

- Develop a migration or compensating control plan for the unsupported legacy operating system, including enhanced segmentation and monitoring (R05)
- Integrate cloud hosted payment platforms into the existing SIEM for full monitoring coverage (R11)
- Develop and formally test a payment processing specific business continuity plan (R17)
- Formalise the regulatory breach notification playbook covering FCA and ICO requirements (R15)
- Strengthen segregation of duties within payment approval workflows through automated dual authorisation (R07)

6.3 Long Term (6 to 12 Months)

- Implement a formal data classification standard across customer financial records (R03)
- Establish continuous or near real time monitoring of privileged account activity (R13)
- Formalise a structured third party risk management programme, including ongoing vendor due diligence (R02)
- Introduce role specific, transaction focused security awareness training for payment handling staff (R10)
- Evaluate secondary cloud hosting arrangements to reduce single provider dependency (R18)

7. Conclusion

The findings in this report indicate that Alderbridge Financial Services Ltd faces a concentrated set of high priority risks centred on legacy infrastructure, testing discipline and monitoring coverage, rather than a broad absence of controls. This is a favourable starting position: the organisation's existing control framework provides a reasonable foundation, and the recommended remediation roadmap is designed to close the highest impact gaps within a realistic and achievable timeframe. Sustained executive sponsorship and clear ownership at the level set out in the risk register will be critical to delivering this roadmap and reducing the organisation's overall risk exposure within the next 12 months.

Appendix A: Risk Scoring Reference

The table below summarises the risk rating produced for each combination of likelihood and impact score.

Likelihood \ Impact	1	2	3	4	5
1	1	2	3	4	5
2	2	4	6	8	10
3	3	6	9	12	15
4	4	8	12	16	20
5	5	10	15	20	25

Appendix B: Assumptions and Limitations

This assessment is based on a structured review informed by common risk patterns observed across comparable financial services organisations and does not constitute a technical penetration test, vulnerability scan or formal audit. Risk ratings reflect professional judgement applied against the scoring criteria set out in Section 3 and should be periodically reassessed as controls are implemented and the threat landscape evolves.

This document uses a fictional organisation, Alderbridge Financial Services Ltd, constructed for the purpose of demonstrating a structured cybersecurity risk assessment methodology.

Appendix C: Glossary of Terms

NIST CSF: National Institute of Standards and Technology Cybersecurity Framework, a voluntary framework of standards and best practices to help organisations manage cybersecurity risk

Inherent Risk: The level of risk present before any controls are applied

Residual Risk: The level of risk remaining after existing controls have been taken into account

MFA: Multi Factor Authentication

SIEM: Security Information and Event Management

PCI DSS: Payment Card Industry Data Security Standard

FCA: Financial Conduct Authority

ICO: Information Commissioner's Office

BCP: Business Continuity Plan